7. Alignment of Security Function to Business Strategy, Goals, Mission, and Objectives

Security management planning ensures the proper creation, implementation, and enforcement of a security policy, aligning security functions with the strategy, goals, mission, and objectives of the organization. This includes designing and implementing security based on business cases, budget restrictions, or scarcity of resources.

- **Business Case:** A documented argument or stated position to define a need to make a decision or take some action, demonstrating a business-specific need to alter an existing process or choose an approach to a business task. It is often used to justify starting a new security-related project.
- **Resource Limitations:** Because money, people, technology, and space are limited in most organizations, the maximum benefit needs to be obtained from any endeavor.
- **Top-Down Approach:** One of the most effective ways to tackle security management planning. Upper or senior management initiates and defines policies for the organization to provide direction for all levels, while middle management fleshes out the security policy into standards, baselines, guidelines, and procedures.
- **Bottom-Up Approach:** The opposite of the top-down approach, where IT staff makes security decisions directly without input from senior management. This approach is rarely used and is considered problematic in the IT industry.
- **Executive Roles in Strategy:** The Chief Information Officer (CIO) focuses on ensuring information is used effectively to accomplish business objectives, while the Chief Technical Officer (CTO) focuses on ensuring equipment and software work properly to support business functions.

8. Organization Roles and Responsibilities

Elements of security management planning include defining security roles, prescribing how security will be managed, assigning responsibility, and establishing testing methods. The best security plan is useless without senior management approval and commitment.

Role / Title	Core Responsibility and Duties
Senior Manager / Senior Management	Ultimately responsible for the security maintained by an organization and protecting its assets; must sign off on all security issues, exercises due diligence and due care, and is held legally liable for failures.
Security Professional / InfoSec Officer / CIRT	Trained and experienced engineer responsible for following directives mandated by senior management, including writing and implementing the security policy (implementers, not decision-makers).
Asset Owner / Data Owner	High-level manager responsible for classifying information for placement and protection within the security solution, typically delegating daily management tasks to a custodian.
Custodian	Responsible for the operational tasks of implementing controls and providing daily maintenance.

Role / Title	Core Responsibility and Duties
User / End User	Responsible for complying with organizational security policies, handling data responsibly in daily tasks, and reporting security anomalies or incidents.
Auditor	Responsible for independently verifying and evaluating security controls, policies, and practices to ensure compliance with internal guidelines, regulations, and industry standards.

9. Due Diligence and Due Care

- **Due Diligence:** The research, investigation, and planning phase that involves discovering risks, evaluating third parties, and ensuring proper preparation.
- **Due Care:** The execution phase and practical operational procedures taken to protect assets, implement security policies, and prevent negligence or legal liability. Developing and implementing a security policy serves as tangible evidence of senior management's due diligence and due care.

10. Security Policy, Standards, Procedures, and Guidelines

- **Security Policy:** The top tier of formalization defining the scope of security, assets requiring protection, security objectives, vision, and goals. Policies can be organizational, issue-specific (e.g., network service, department), or system-specific.
- **Standards:** Define compulsory requirements for the homogenous use of hardware, software, technology, and security controls.
- **Baselines:** Define the minimum level of security that every system throughout the organization must meet before entering production.
- **Guidelines:** Offer recommendations and operational advice on how standards and baselines are implemented.
- **Procedures:** Step-by-step instructions detailing how to execute security operations.

11. Threat Modeling

Threat modeling is a proactive engineering process used during application and system design to anticipate adversary tactics and prioritize defenses.

11.1 Threat Identification Approaches

Threat modeling generally approaches threat identification through three primary perspectives:

- **Attacker-Focused (Adversary-centric):** Identifies potential attackers and evaluates their motivations, goals, capabilities, and attack vectors to anticipate how they might compromise the system.
- **Software-Focused (Software-centric / System-centric):** Deconstructs the software design, architecture, and code logic to uncover flaws, trust boundary issues, and vulnerable routines.
- **Asset-Focused (Asset-centric):** Starts by inventorying critical organizational assets and evaluates all potential threats that could endanger those specific assets.

11.2 STRIDE Threat Model (Microsoft)

STRIDE is a widely recognized threat modeling methodology developed by Microsoft that categorizes security threats into six distinct areas matching specific security goals:

Threat Category	Definition & Impact	Violated Security Property
Spoofing	Impersonating a person, user account, or system to gain unauthorized access.	Authenticity / Confidentiality
Tampering	Maliciously modifying data at rest, in transit, or system configuration settings.	Integrity
Repudiation	Denying having performed an action or transaction due to lack of proof.	Nonrepudiation / Accountability
Information Disclosure	Exposing sensitive data to unauthorized individuals or system processes.	Confidentiality
Denial of Service (DoS)	Degrading, disrupting, or rendering system services unavailable to legitimate users.	Availability
Elevation of Privilege	Gaining higher permissions or admin rights than originally authorized.	Authorization / Integrity

11.3 Diagramming Potential Attacks (Data Flow Diagram)

Diagramming elements involved in transactions helps reveal threat concerns across trust boundaries, data flows, and storage containers.

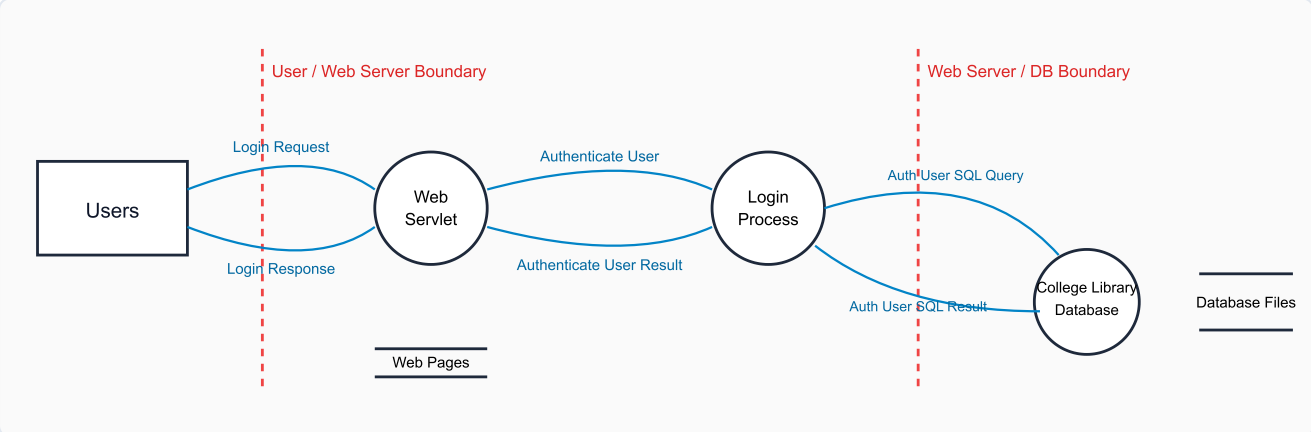


FIGURE 1: An example of diagramming to reveal threat concerns across trust boundaries.

11.4 Performing Reduction Analysis (Decomposition)

Gaining a granular understanding of product logic by breaking systems down into subroutines, modules, or objects to analyze five key concepts:

1. *Trust Boundaries:* Locations where the level of trust or security changes.
2. *Dataflow Paths:* The movement of data between locations.
3. *Input Points:* Locations where external input is received.
4. *Privileged Operations:* Activities requiring greater privileges than standard user accounts.
5. *Security Stance and Approach:* Declarations of policy foundations and security assumptions.

11.5 Prioritization and Response

Ranking threats using techniques such as Probability × Damage Potential, risk matrices/heat maps, or the **DREAD** rating system (*Damage, Reproducibility, Exploitability, Affected Users, Discoverability*).

Criticality prioritization ranks threats by mapping their probability of occurrence against their damage potential:

Damage Potential	Probability		
	Low (L)	**Medium (M)**	**High (H)**
High (H)	HL (High/Low)	HM (High/Med)	**HH (High/High)**
Medium (M)	ML (Med/Low)	MM (Med/Med)	MH (Med/High)
Low (L)	LL (Low/Low)	LM (Low/Med)	LH (Low/High)

FIGURE 2: A 3×3 Risk Matrix / Risk Heat Map mapping Probability against Damage Potential.

12. Understand and Apply Risk Management Concepts

Risk management is the detailed process of identifying factors that could damage or disclose assets, evaluating those factors against asset values and countermeasure costs, and implementing cost-effective solutions to mitigate or reduce risk to an acceptable level.

12.1 Key Terminology & Concepts

- **Asset:** Anything used in a business process or task. If an organization relies on a person, place, or thing (tangible or intangible), it is an asset.
- **Asset Valuation (AV):** The assigned value of an asset based on importance, actual cost, nonmonetary expenses, and productivity impact.
- **Threat:** Any potential occurrence that may cause an undesirable outcome for an organization or a specific asset.
- **Threat Agent / Actor:** Entities (attackers, malware, disgruntled employees) that intentionally exploit vulnerabilities.
- **Threat Event:** Accidental or intentional occurrences (fire, system failure, power outage) exploiting vulnerabilities.
- **Threat Vector:** The path or means by which a threat agent gains access to a target (email, Wi-Fi, USB drives).
- **Vulnerability:** Weakness in an asset or absence of a safeguard/countermeasure.
- **Exposure:** Being susceptible to asset loss because of a threat.

- **Risk:** The possibility or likelihood that a threat will exploit a vulnerability to cause harm, expressed as: `Risk = Threat × Vulnerability` or `Risk = Probability of Harm × Severity of Harm`
- **Safeguard (Countermeasure):** Anything that removes or reduces a vulnerability or protects against threats. Reconfiguring existing elements or removing risky services are also valid safeguards.
- **Attack:** Intentionally exploiting a vulnerability by a threat agent. A malicious event does not have to succeed to be considered an attack.
- **Breach:** A successful attack where a security mechanism is bypassed or thwarted.
- **Hazard:** A potential source or situation that has the capability to cause harm or adverse consequences.

12.2 Cyclical Relationships of Risk Elements

Threats exploit vulnerabilities, which results in exposure. Exposure is a risk, and risk is mitigated by safeguards. Safeguards protect assets that are endangered by threats.

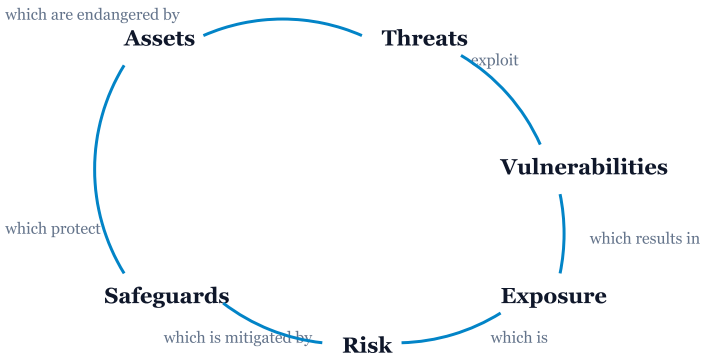


FIGURE 3: The cyclical relationships of risk elements.